THE EQUIFAX DATA BREACH – DATA SECURITY AND PRIVACY FAILURE

CASE STUDY REPORT

submitted by

AKSHAY K P (VML24AD017)

As part of the Case Study under Continuous Internal Evaluation in the course

PEADT412 – Data Science Privacy & Ethics

Vimal Jyothi Engineering College, Chemperi

(March 2026)

Contents

1 Introduction **2**

2 Background of the Organization **2**

3 Problem or Violation Description **3**

3.1 The Vulnerability 3

3.2 The Attack 3

3.3 Data Exposed 4

3.4 Detection and Disclosure 4

4 Analysis: Laws and Principles Violated **4**

4.1 Fair Credit Reporting Act (FCRA) 4

4.2 Federal Trade Commission Act 5

4.3 General Data Protection Regulation (GDPR) 5

4.4 Data Ethics Principles Violated 5

5 Impact and Consequences **6**

5.1 Impact on Affected Individuals 6

5.2 Impact on Equifax 6

5.3 Industry-Wide Impact 6

6 Actions Taken and Penalties **7**

6.1 Regulatory Settlement 7

6.2 Operational Requirements 7

6.3 United Kingdom Penalty 7

6.4 Executive Accountability 7

7 Recommendations and Preventive Measures **8**

7.1 Automated Patch Management 8

7.2 Network Segmentation and Zero Trust Architecture 8

7.3 Encryption of Data at Rest 8

7.4 Continuous Security Monitoring 9

7.5 Data Minimization and Retention Policies 9

7.6 Transparent Incident Response Planning 9

8 Conclusion **10**

9 References **10**

1 Introduction

Data breaches have become one of the defining crises of the digital age. They expose the personal information of millions of people, erode public trust in institutions, and reveal deep failures in how organizations manage the sensitive data they are entrusted to protect. Among all the major cybersecurity incidents of the past decade, the Equifax data breach of 2017 stands out as one of the most severe, consequential, and widely studied.

Equifax is one of three major consumer credit reporting agencies in the United States. The company maintains detailed financial records on hundreds of millions of individuals worldwide. These records include Social Security numbers, credit histories, employment records, home addresses, and date of birth information. The data Equifax holds is extraordinarily sensitive.

A breach of this information does not merely inconvenience victims. It exposes them to identity theft, financial fraud, and long-term harm that can persist for years or even decades. In the summer of 2017, attackers exploited a known vulnerability in Equifax's web application infrastructure. The breach went undetected for more than two months. By the time it was discovered and publicly disclosed, the personal data of approximately 147 million individuals had been compromised.

The scale of the incident, the sensitivity of the stolen data, and the clear preventability of the attack made this breach a landmark event in data security and privacy ethics. This case study examines the incident in full, analyzing the background of the organization, the nature of the violation, the laws and principles that were broken, the impact on affected individuals, the penalties that followed, and the lessons that the case offers for future data governance practice.

2 Background of the Organization

Equifax Incorporated was founded in 1899 under the name Retail Credit Company and is headquartered in Atlanta, Georgia, United States. It is one of the three largest consumer credit reporting agencies in the world, alongside Experian and TransUnion. Equifax operates in more than 24 countries and employs approximately 11,000 people globally. As of 2017, the company reported annual revenues exceeding 3.3 billion dollars.

As a credit bureau, Equifax collects and maintains financial data on individual consumers and then sells access to that data to lenders, employers, insurance companies, landlords, and other entities that need to assess an individual's financial background

or creditworthiness. This service forms the core of the credit reporting industry, which underpins lending decisions across the entire economy.

The credit reporting industry occupies a uniquely powerful and sensitive position in the data ecosystem. Credit bureaus collect data that individuals have no practical ability to withhold. When a person opens a bank account, applies for a loan, or misses a payment, that information flows automatically to credit bureaus. Consumers cannot choose which bureau holds their data, cannot negotiate the terms on which it is retained, and cannot in most circumstances demand its deletion.

This involuntary data relationship creates exceptionally high ethical and legal responsibilities. The data that Equifax holds directly determines whether individuals can obtain housing, employment, or credit. Errors in credit records cause serious and sometimes irreversible financial harm. Breaches of credit data enable identity theft at a scale that can permanently damage a victim's financial standing. Equifax's core business proposition was built entirely on being a secure and trustworthy custodian of this information. The 2017 breach represented a fundamental failure of that proposition.

3 Problem or Violation Description

3.1 The Vulnerability

The Equifax breach originated with a publicly known security vulnerability in the Apache Struts web application framework, identified as CVE-2017-5638. Apache Struts is a widely used open-source framework for building Java-based web applications. The flaw was located in the Jakarta Multipart Parser component and allowed remote code execution by manipulating the Content-Type HTTP header in file upload requests.

The vulnerability was publicly disclosed on March 7, 2017. A patch was released the same day by the Apache Software Foundation. The United States Computer Emergency Readiness Team immediately notified organizations known to use Apache Struts. Equifax received this notification and acknowledged it internally. Despite this, the company failed to apply the critical patch within any reasonable timeframe. The patch remained uninstalled across multiple Equifax servers for more than nine weeks.

3.2 The Attack

Attackers began exploiting the unpatched vulnerability on May 13, 2017. By sending specially crafted HTTP requests to Equifax's publicly accessible web servers, the

attackers were able to execute arbitrary commands on the server without any authentication. This type of attack is classified as remote code execution and is among the most dangerous categories of security vulnerabilities because it requires no valid credentials.

After establishing initial access, the attackers deployed web shells and other malicious tools to maintain persistent access to Equifax's systems. They then moved laterally through Equifax's internal network, identifying and accessing databases containing consumer credit records. Over a period of approximately 76 days, the attackers exfiltrated data from at least 48 distinct databases.

3.3 Data Exposed

The breach exposed the personal information of approximately 147 million individuals, representing nearly half the population of the United States. The categories of data stolen included full names, Social Security numbers, dates of birth, home addresses, and driver's license numbers. Credit card numbers for approximately 209,000 individuals were also stolen. Additionally, dispute documents containing personal identifying information for approximately 182,000 people were accessed.

3.4 Detection and Disclosure

The breach was not detected until July 29, 2017, more than two and a half months after the attackers first gained access. Equifax's security team discovered the intrusion only after an internal network inspection. The company did not disclose the breach to the public until September 7, 2017, a gap of forty days between discovery and disclosure. During this period, three senior Equifax executives sold company shares worth approximately 1.8 million dollars combined.

4 Analysis: Laws and Principles Violated

4.1 Fair Credit Reporting Act (FCRA)

The Fair Credit Reporting Act is the primary United States federal law governing consumer credit reporting agencies. It imposes obligations on credit bureaus to maintain the accuracy and security of consumer credit information. Equifax's failure to implement adequate security controls to protect the sensitive data it held constitutes a violation of its FCRA obligations. The act requires credit reporting agencies to use reasonable procedures to ensure the security of consumer information.

4.2 Federal Trade Commission Act

Section 5 of the Federal Trade Commission Act prohibits unfair or deceptive acts or practices in commerce. The FTC has consistently held that a company's failure to implement reasonable security measures for sensitive personal data constitutes an unfair practice under this provision. Equifax's failure to patch a known critical vulnerability, its inadequate network monitoring, and its lack of data encryption all fall within the scope of unreasonable security practices as defined by FTC enforcement standards.

4.3 General Data Protection Regulation (GDPR)

Although the GDPR formally came into force in May 2018, after the breach occurred, it provides the most comprehensive analytical framework for evaluating Equifax's violations from a data ethics perspective. The breach violated several core GDPR principles. The principle of integrity and confidentiality requires that personal data be protected against unauthorized access through appropriate technical and organizational measures. Equifax demonstrably failed this requirement. The principle of storage limitation requires that data be retained only as long as necessary. Equifax retained sensitive personal data across multiple systems without adequate justification for the retention period. The 72-hour breach notification requirement under GDPR would also have been violated by Equifax's 40-day disclosure delay.

4.4 Data Ethics Principles Violated

Beyond formal legal violations, the Equifax breach violated multiple foundational principles of data ethics. Accountability requires that organizations take active responsibility for protecting the data entrusted to them. Equifax had no functional patch management system and no effective network anomaly detection, demonstrating a systemic absence of accountability. Transparency requires that individuals be informed promptly when their data is compromised. The 40-day disclosure delay directly violated this principle, denying victims the ability to take protective action during the window when timely intervention could have limited harm. The principle of data minimization requires collecting and retaining only what is genuinely necessary. Equifax retained sensitive personal data across dozens of database systems without clear operational justification, unnecessarily expanding the attack surface.

5 Impact and Consequences

5.1 Impact on Affected Individuals

The personal harm to the 147 million affected individuals is the most important dimension of the breach's impact. Social Security numbers are the most sensitive personal identifier in the United States. Unlike a password or even a credit card number, a Social Security number cannot be changed or reissued in ordinary circumstances. Once a Social Security number is combined with a date of birth and home address, it can be used to open fraudulent credit accounts, file false tax returns, impersonate the individual to government agencies, or conduct a range of other forms of identity fraud.

The harm profile of the Equifax breach is therefore not merely severe but potentially permanent. Victims face elevated fraud risk not for months but for the remainder of their lives. The 40-day disclosure delay compounded this harm significantly. During those forty days, victims had no knowledge that their information had been compromised and therefore took no protective action. Fraudulent activity using the stolen data began appearing within weeks of the breach, and in many cases victims discovered the problem only after fraudulent accounts had already been opened and damaged their credit records.

5.2 Impact on Equifax

The reputational damage to Equifax was immediate and severe. The company's share price fell by more than 30 percent in the weeks following the public disclosure. Congressional hearings, regulatory investigations, and extensive media coverage sustained public pressure on the company for months. The company spent more than 1.4 billion dollars in the two years following the breach on security improvements, legal fees, customer notification programs, and regulatory compliance costs.

5.3 Industry-Wide Impact

The breach triggered a broad reassessment of data security practices across the financial services and data brokerage industries. Regulators in the United States, United Kingdom, and European Union all launched reviews of data broker security practices. The incident provided concrete evidence supporting the case for stronger data protection legislation and contributed to the momentum behind GDPR enforcement after it came into force in 2018.

6 Actions Taken and Penalties

6.1 Regulatory Settlement

In July 2019, Equifax reached a global settlement with the United States Federal Trade Commission, the Consumer Financial Protection Bureau, and the attorneys general of all 50 states and the District of Columbia. The total settlement value was up to 700 million dollars, making it the largest data breach settlement in United States history at the time.

Of this amount, up to 425 million dollars was allocated to a consumer restitution fund to compensate individuals who could demonstrate harm resulting from the breach. Equifax was required to provide all affected consumers with ten years of free credit monitoring services. The remaining 275 million dollars was distributed as civil penalties to state and federal regulators.

6.2 Operational Requirements

In addition to financial penalties, the settlement imposed extensive ongoing operational requirements on Equifax. The company was required to implement a comprehensive information security program meeting specific technical standards. It was required to submit to independent third-party security assessments every two years for a period of twenty years. These requirements effectively placed Equifax under long-term regulatory supervision of its security practices.

6.3 United Kingdom Penalty

The United Kingdom's Information Commissioner's Office investigated Equifax's UK subsidiary separately. In September 2018, the ICO issued a fine of 500,000 pounds, the maximum penalty available under the Data Protection Act 1998 that was in force at the time of the breach. The ICO found that Equifax had failed to take appropriate technical and organizational measures to protect the personal data of UK residents. The regulator noted that under the GDPR framework that came into force in 2018, the same violations would have been subject to fines of up to 17 million pounds or four percent of global annual turnover, whichever was greater.

6.4 Executive Accountability

Equifax CEO Richard Smith resigned on September 26, 2017, nineteen days after the public disclosure of the breach. The company's Chief Information Officer and Chief Security Officer also departed within weeks. Congressional hearings produced

extensive critical testimony about executive oversight and organizational dysfunction. The executives who sold shares prior to the public disclosure were investigated by the Department of Justice for potential insider trading, though no charges were ultimately filed.

7 Recommendations and Preventive Measures

7.1 Automated Patch Management

The Equifax breach was entirely preventable. A publicly known vulnerability had a patch available on the same day it was disclosed. That patch was never installed. This single failure caused the largest consumer data breach in United States history at the time.

Organizations managing sensitive data must deploy automated patch management systems. These systems should track deployment status across every server and device in the environment. When a critical patch is not installed within a defined window, automated alerts must escalate to senior management. Manual patch tracking is unreliable at enterprise scale. Automation removes the human dependency that failed so catastrophically at Equifax.

7.2 Network Segmentation and Zero Trust Architecture

Network segmentation is a foundational security control. It limits how far an attacker can move after gaining initial access to one system. Equifax's attackers moved from a single web server to 48 separate databases. This lateral movement should never have been possible.

Organizations should isolate sensitive databases behind strict access controls. No web-facing application should have direct database access beyond what its function strictly requires. The zero trust model requires every access request to be authenticated and logged, regardless of where it originates on the network. Sensitive data should only be reachable through explicitly approved, audited pathways.

7.3 Encryption of Data at Rest

Encryption limits the damage of a breach. It does not prevent unauthorized access. But it makes stolen data useless to the attacker without the decryption key.

Social Security numbers, dates of birth, and financial records should be encrypted at rest using current industry-standard algorithms. Equifax stored these records in accessible plaintext form. The moment the attackers exfiltrated the data, it was

immediately ready for criminal use. Strong encryption would have converted 147 million identity records into unreadable files, dramatically reducing the real-world harm to victims.

7.4 Continuous Security Monitoring

The Equifax breach lasted 76 days without detection. Attackers accessed 48 databases and transferred enormous volumes of data. No alert was triggered. This represents a complete failure of security operations.

Organizations must deploy real-time monitoring of database access, network traffic, and user behavior. Anomaly detection tools should flag large or unusual data transfers immediately. Security teams need automated alerts, not manual log reviews. Any system that transfers sensitive data to external destinations outside of normal operational patterns should trigger an immediate investigation. Detection speed is critical because every day a breach continues, more data is stolen and more victims are harmed.

7.5 Data Minimization and Retention Policies

Less data means less risk. Organizations should collect only what is genuinely necessary for their business purpose. They should retain it only for as long as the purpose requires.

Equifax held sensitive records across dozens of systems. Some of that data had no clear current operational need. Every unnecessary record adds to the attack surface. Formal retention policies should specify deletion timelines for each data category. These policies must be technically enforced, not just documented. Automated deletion schedules should be audited annually by independent reviewers.

7.6 Transparent Incident Response Planning

Equifax discovered the breach on July 29, 2017. The public was not informed until September 7. Those forty days were lost. Victims could not freeze their credit, alert their banks, or monitor for fraud.

Organizations must have documented incident response plans tested before a breach occurs. The plan should define who is responsible at each stage, what the disclosure timeline is, and how affected individuals will be notified. Prompt and honest disclosure is both an ethical obligation and a legal requirement in most jurisdictions. Organizations that disclose quickly demonstrate accountability. Those that delay compound the original harm with a second violation of trust.

8 Conclusion

The Equifax data breach of 2017 changed how the world thinks about data security and corporate accountability. It exposed the personal information of 147 million people. It caused widespread financial harm. It triggered the largest data breach settlement in United States history. And it revealed, with uncomfortable clarity, how deeply an organization can fail its responsibilities to the people whose data it holds.

The breach was preventable at every stage. A known vulnerability went unpatched for nine weeks. The intrusion went undetected for 76 days. The public was kept uninformed for 40 days after discovery. These were not isolated technical accidents. They were the product of a security culture that treated compliance as a checkbox and sensitive personal data as a business asset rather than a trust.

Each failure maps directly to the curriculum of Data Science Privacy and Ethics. Module 1 is addressed in the risk management failure, the nature of the sensitive data exposed, and the ethical violations of accountability and transparency. Module 2 is addressed in the privacy violations sustained by 147 million individuals, the absence of anonymization and data minimization practices, and the cascading impact through credit scoring systems. Module 3 is addressed in the technical analysis of the Apache Struts exploit, the lateral movement through unsegmented databases, the absence of encryption, and the complete failure of security monitoring.

Security is not a product. It cannot be purchased once and forgotten. It requires continuous investment, rigorous governance, and an organizational culture that genuinely values the privacy and safety of the people whose data it manages. Equifax failed all of these requirements. The consequences were historic. The lessons, properly internalized, can help ensure that organizations handling sensitive personal data do not repeat them.

9 References

1. United States Senate Permanent Subcommittee on Investigations. (2019). *How Equifax Neglected Cybersecurity and Suffered a Devastating Data Breach.* U.S. Government Publishing Office.

2. Federal Trade Commission. (2019). *Equifax Data Breach Settlement.* FTC Consumer Information. Retrieved from https://www.ftc.gov/equifax.

3. Apache Software Foundation. (2017). *S2-045: Possible Remote Code Execution when performing file upload based on Jakarta Multipart parser (CVE-2017-5638).*

Apache Security Bulletins.

4. Information Commissioner's Office. (2018). *Equifax Ltd – Monetary Penalty Notice*. ICO Enforcement Actions, United Kingdom.

5. Solove, D. J. (2006). A Taxonomy of Privacy. *University of Pennsylvania Law Review*, 154(3), 477–564.

6. OWASP Foundation. (2021). *OWASP Top Ten Web Application Security Risks*. OWASP.org.

7. European Union. (2018). *General Data Protection Regulation (GDPR)* – Regulation (EU) 2016/679.

8. National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity*.

9. Romanosky, S. (2016). Examining the Costs and Causes of Cyber Incidents.

10. Krebs, B. (2017). *Equifax Breach Response Turns Dumpster Fire*.